Ubuntu Digital Bank: Top Risks Summary

GRC risk register (fictional South African digital bank) | Prepared by Siyabonga Msengana | Illustrative learning exercise, not a real assessment

Overview

The register covers 11 banking and IT risks scored on a 5x5 likelihood and impact matrix. Nine of the 11 sit in the High inherent band and one is Critical (R-001). After controls, residual risk drops to Medium for most, but three stay High: R-001 account takeover, R-009 employee phishing and R-011 inconsistent evidence retention. The five below are the ones I would put in front of management first, ranked by residual score, with ties at 10 broken by customer and regulatory impact.

Top 5 risks

Rank	Risk	Inherent	Residual	Why it matters	Key next action
1	R-001 Customer account takeover	20 Critical	15 High	Direct customer harm and financial loss. Monitoring and recovery tests improved, but phishing awareness is still partial.	Finish phishing training and retests; authorised owner reviews residual rating.
2	R-009 Employee falls for phishing	16 High	12 High	Staff compromise leads to fraud or data exposure. Simulation: 20 of 100 clicked, 5 entered credentials.	Targeted awareness exercise; track repeat clickers and reporting rate.
3	R-011 Inconsistent evidence retention	12 High	12 High	Without retained evidence the bank can't prove controls work. Controls are weak or not demonstrated.	Approve bank-wide retention policy and secure repository; periodic checks.
4	R-003 Unauthorised exposure of customer data	15 High	10 Medium	Privacy harm, investigation costs and regulatory consequences if access or configuration fails.	Quarterly access reviews; verify encryption, logging and alerting.
5	R-007 Suspicious transactions not detected promptly	15 High	10 Medium	Fraudulent transfers could continue before intervention, increasing losses.	Review alert thresholds and backlog; test scenarios; set response times.

Key finding from control testing

Simulated tests on R-001 showed real improvement after fixes: login alerts went from 18/20 to 20/20 and account recovery from 3/4 to 4/4. Passing retests is not the same as being safe, so the risk stays High until phishing awareness is addressed and an authorised owner signs off. For R-011, a successful retest could not restore evidence that had already been deleted, which is why a bank-wide process is needed rather than department fixes.

Governance note

Risk owners are accountable for treatment or acceptance, control owners operate the controls, and independent audit evaluates effectiveness. Closing an action does not automatically close the risk.

Limitations

All scenarios, scores, owners, dates and test results are fictional and illustrative. Only R-001 and R-011 were assessed in depth. R-011 scores are preliminary and need formal validation.